GITHUB SECURITY LAB · FINAL INTERVIEW

Prep Packet

Two talks · behavioral · research · questions

Rod Trent · print-and-go · generated October 03, 2026

1. **Speaker cheat sheet** — Part A — Presentations
2. **Dry-run & day-of checklist**
3. **Technical follow-up bank**
4. **Behavioral drafts — Themes 1, 4, 8** — Part B — Behavioral
5. **Behavioral drafts — Themes 2, 9**
6. **Behavioral draft — Theme 6**
7. **Behavioral workbook (remaining themes)**
8. **GitHub Security Lab — research brief** — Part C — Research & questions
9. **Questions to ask them**

Talks: "CodeQL — Find the bug class, not just the bug" and "Breaking the chain — disrupting supply chain attacks on npm & GitHub Actions." Full decks (with speaker scripts in the notes), demos, and runbooks live in the repo: github.com/rod-trent/GHJ

PART A — PRESENTATIONS

Speaker cheat sheet

Two talks. Problem first, then tech, then demo, then takeaway. Each slide has full speaker notes in the .pptx — this is the one-page version for the day.

Talk 1 — CodeQL (12 slides, ~12 min + Q&A)

Beat	Slides	~min
Problem: grep can't follow data flow; one bug class, many faces	1–2	2
Why it matters: scale + leverage (one query protects everyone)	3	1
Solution: code as data → QL query → results	4	1.5
Demo app "Octo Notes" + its deliberate blind spot	5	1
DEMO Act 1: default suite misses the SQLi	6	1.5
Models-as-data: one line of YAML	7	1
DEMO Acts 2–3: SQLi found + the QL query	8	2
Bridge: CodeQL also scans Actions (→ talk 2)	9	1
In the PR + Copilot Autofix	10	1
Impact + takeaways	11–12	1.5

One-liner: *"Describe the bug once, catch it everywhere."*

Demo command: `cd demos\codeql; .\run-codeql-demo.ps1`

Talk 2 — Supply chain (13 slides, ~13 min + Q&A)

Beat	Slides	~min
Problem: self-replicating attacks — compromise → steal → propagate	1–2	2
Why it matters: you run far more code than you read	3	1
Strategy: break every link (the map)	4	1
DEMO 1: install scripts — npm 11 runs it, npm 12 blocks it	5–6	3
CI is the other door (script injection, pwn request) → CodeQL	7	1
Walk-through (not live): issue title runs code, then the fix	8	2
Prevention: safe-by-default CI	9	1
Prevention: kill the token (OIDC, staged publish, revoke)	10	1
Containment: Dependabot cooldown	11	0.5
Impact + takeaways	12–13	1.5

One-liner: *"Make the attack expensive at every step."*

One live demo (slides 5–6): `cd demos\supply-chain\npm-install-scripts; .\run-demo.ps1` (run `-Prep` once on wifi first). Slide 8 is a **visual walk-through**, not performed. *Optional* live Actions injection is available if they ask — see runbook (enable the demo workflow first).

Key facts to have right (dates are 2026)

- **npm 12** (~July 2026): install scripts **off by default** (`allowScripts`); `--allow-git` , `--allow-remote` , etc. default to restricted. Needs **Node ≥ 24.15**.
- **actions/checkout** (enforced July 20, 2026): refuses untrusted fork checkout on `pull_request_target` / `workflow_run` unless you add `allow-unsafe-pr-checkout` .
- **Trusted publishing (OIDC)**: no long-lived `NPM_TOKEN` ; provenance auto-signed. CircleCI added April 2026.
- **Staged publishing** (`npm stage publish` , npm ≥ 11.15): human + 2FA approval before a package is installable; can be set "stage-only".
- **Dependabot cooldown** (July 2026): `cooldown:` in `dependabot.yml` , default delay for **version** updates; **security updates are never delayed**.
- **npm account protection** (June 2026): 72-hour read-only on email change / 2FA recovery.
- CodeQL workflow queries: `actions/code-injection` , `actions/untrusted-checkout` .

Likely Q&A

- *"Does modeling cause false positives?"* — Precision is tuned per sink kind; the demo shows the safe parameterized endpoint stays silent. You can also scope models and add `test` /sanitizer models.
- *"Does CodeQL need to build the code?"* — JS/TS and Actions use `build-mode: none` ; compiled languages need a build or autobuild.
- *"Is GitHub Advanced Security required?"* — Code scanning is free on public repos; GHAS for private. That's why the demo repo is public.
- *"Won't blocking install scripts break my build?"* — You approve the ones you need once (`npm install-scripts approve`), recorded in `package.json` . Most packages don't need them.
- *"Can't an attacker just name the flag / use a different sink?"* — The checkout flag is deliberately loud for review/CodeQL; new sinks are handled by adding a model (the talk's point).
- *"OIDC — what if I publish from somewhere other than GitHub/CircleCI?"* — Trusted publishing is per-provider; otherwise scope a short-lived token + staged publishing.

Dry-run & day-of checklist

Two talks, three live demos. Work top to bottom. Boxes you can tick: `[ ]`.

T-minus 1 day — environment (do this on wifi, not at the venue)

- [ ] **Node version supports npm 12** — needs ≥ **24.15.0**: `bash node -v` If lower, upgrade (e.g. `nvm install 24` / install latest 24.x) and re-check. npm 12 still *blocks* on older Node but prints an engine warning on screen.
- [ ] **CodeQL CLI present** at `C:\Code\tools\codeql\codeql.exe`: `bash C:\Code\tools\codeql\codeql.exe version` If missing, download `codeql-bundle-win64.tar.*` from https://github.com/github/codeql-action/releases and extract to `C:\Code\tools\codeql`.
- [ ] **Deck build deps installed** (only if you plan to rebuild): `bash cd presentation/build && npm install --ignore-scripts`
- [ ] **gh authenticated** to the right account: `bash gh auth status`
- [ ] **Pre-cache npm 11 & 12** so Demo 1 runs offline and fast: `bash cd demos/supply-chain/npm-install-scripts && pwsh -File run-demo.ps1 -Prep`
- [ ] **Open the decks once** in PowerPoint; confirm Presenter View shows the speaker notes.
- [ ] **Full rehearsal** of both talks end to end, timed (target 12–13 min each + Q&A).

T-minus 1 hour — pre-flight at the venue

- [ ] Laptop charged + charger plugged in; screen-sleep / screensaver **off**.
- [ ] Display mirroring tested on the projector; font sizes legible from the back.
- [ ] **Terminal font bumped up** (≥ 18pt) for the demo terminals.
- [ ] Browser logged in to GitHub; close noisy tabs, notifications, Slack/email.
- [ ] These tabs pre-opened:
- [ ] `github.com/rod-trent/octo-notes-demo` → **Security** → **Code scanning** (shows the 8 alerts)
- [ ] The merged **PR #2** (the fix): `gh pr view 2 -R rod-trent/octo-notes-demo --web`
- [ ] The repo's **Actions** tab
- [ ] Decks open in **Presenter View**; one-pager PDF handy if anyone wants it.
- [ ] Verify network — or decide to run **fully offline** (both local demos work offline).

Talk 1 — CodeQL (demo pre-flight)

- [ ] Terminal open at repo root; CodeQL CLI on PATH or use full path.
- [ ] Dry-run the 3-act script once so the DB is pre-built (keeps the live run snappy): `bash cd demos/codeql && pwsh -File run-codeql-demo.ps1`
- [ ] Confirm you saw: Act 1 misses SQLi → Act 2 finds both + safe one silent → Act 3 query.
- [ ] **Backup ready:** `demos/backup/codeql-1..4-*.csv` open in an editor, in case the CLI stalls.

- [ ] Decide whether you'll also show the live alerts in the Security tab (needs network).

Run order on stage: slides 1–5 → **demo Act 1** (slide 6) → slide 7 → **demo Acts 2–3** (slide 8) → slides 9–12 → Q&A.

Talk 2 — Supply chain (demo pre-flight)

Demo 1 — npm install scripts (local, offline-safe) - [ ] `node -v` ≥ 24.15 (re-confirm on the venue machine). - [ ] Dry-run once: `bash cd demos/supply-chain/npm-install-scripts && pwsh -File run-demo.ps1` - [ ] Confirm: npm 11 runs the postinstall ("harvested … / would POST / would re-publish"); npm 12 **blocks** it.

Slide 8 is a walk-through, not a live demo — you just talk over the vulnerable-vs-hardened slide. The live attack below is now **OPTIONAL** (only if they ask to see it fire).

Optional live Actions injection (needs network) - [ ] **Enable the demo workflow** (it's disabled by default): `bash gh workflow enable "Issue triage (DEMO - vulnerable)" -R rod-trent/octo-notes-demo` - [ ] Have the payload issue title on the clipboard: `Login crash"; echo "PWNED as $(whoami)"; echo "Secret: $(echo $DEPLOY_TOKEN | base64)"; #` - [ ] Know where to click: Actions → **Issue triage (DEMO - vulnerable)** → latest run → *Greet the issue author* step → point at `PWNED as runner` + the base64 secret. - [ ] Fix comparison ready: `issue-triage-demo.yml` (vulnerable) vs hardened `issue-triage.yml` on `main`, plus the merged PR #2. - [ ] **Backup ready:** `demos/backup/actions-injection-run-log.txt` (a captured PWNED run).

Run order on stage: slides 1–4 → **live demo** (slides 5–6) → slide 7 → **walk-through** (slide 8, not performed) → slides 9–13 → Q&A. (Offer the live injection only if asked.)

During each talk — reminders

- [ ] Problem first — don't jump to features.
- [ ] Narrate every demo step: what you're doing, why, what to watch for.
- [ ] If a live demo misbehaves: **switch to the backup file, keep talking, move on** — don't debug on stage.
- [ ] Watch the clock in Presenter View; ~1.5–2 min/slide.
- [ ] Mention the cross-link once per talk (CodeQL ↔ supply chain = detection + prevention).

Teardown (right after Talk 2)

- [ ] **Disable the demo workflow** so it can't fire later: `bash gh workflow disable "Issue triage (DEMO - vulnerable)" -R rod-trent/octo-notes-demo`
- [ ] Close any demo issues you opened: `bash gh issue list -R rod-trent/octo-notes-demo gh issue close <n> -R rod-trent/octo-notes-demo -c "demo cleanup"`
- [ ] Offer the one-pager (`presentation/One-Pager-Leave-Behind.pdf`) and repo link to the panel.

Panic card (if everything breaks)

- No network → both **local** demos (CodeQL CLI, npm) still work; skip the GitHub-UI beats.
- CodeQL CLI fails → walk `demos/backup/codeql-*.csv`.
- Actions slow/failing → walk `demos/backup/actions-injection-run-log.txt`.
- Laptop dies → the decks carry the full script in the notes; the one-pager PDF summarizes both talks.
- Repo: `github.com/rod-trent/GHJ` · Demo app: `github.com/rod-trent/octo-notes-demo`

Technical follow-up bank

Interviewers **will interrupt** and probe. The goal isn't to know everything — it's to reason well out loud and say "I don't know, here's how I'd find out" when you don't. Answers below are crisp talking points, not scripts.

Handling mid-demo interruptions (practice this)

- **Acknowledge, park, or answer briefly.** "Great question — short answer X; let me finish this step and I'll go deeper." Then actually circle back.
- **Never debug silently on stage.** If a command hangs >10–15s, narrate, switch to the backup file, keep the story moving. Your value is the reasoning, not the terminal.
- **If they challenge a claim**, welcome it: "Let's test that" beats defending. You can even run an ad-hoc variation if you know the repo cold.
- Keep a finger on the timer; a good interruption can eat 3 minutes.

Talk 1 — CodeQL

Q: What's actually in the CodeQL "database"? Is it just an AST? More than an AST. Extraction captures the AST plus a relational representation of the program: control-flow graph, the call graph, type information, and the scaffolding for data-flow/taint analysis. QL queries run against that relational model. That's why you can ask "does data flow from here to there," which pure syntax (AST/grep) can't answer.

Q: Difference between data flow and taint tracking? Data flow tracks values through assignments, calls, returns. **Taint tracking** is data flow plus "taint steps" — transformations that preserve attacker control even though the value changes (e.g., string concatenation, `JSON.parse`, templating). SQL injection needs taint tracking because the input gets reshaped on the way to the sink.

Q: Sources, sinks, sanitizers — and how do you cut false positives? Source = attacker-controlled input (`RemoteFlowSource`). Sink = dangerous operation (the SQL call). **Sanitizer/barrier** = a node that makes data safe (e.g., parameterization, an escaping function); you add barriers to the config so paths through them aren't reported. That, plus precise sink modeling, is how you tune precision. In the demo, the parameterized endpoint is clean precisely because a prepared statement isn't a string-concatenation sink.

Q: How is "models as data" different from writing a query? Why is it safer? A query is logic; a model is *data* describing a library's sources/sinks/summaries in YAML. Adding a model teaches **every existing query** about a new library without touching query logic — lower blast radius, easy to review in a PR, versioned, and shippable via `.github/codeql/extensions` where code scanning auto-loads it. Writing a new query is for a new *kind* of bug; modeling is for new *libraries/APIs* exhibiting a known kind.

Q: Could an attacker evade your model by using a different method/alias? Yes — models are as complete as you make them. That's the honest limitation and the reason the bounty/community model exists: you broaden coverage by modeling more entry points, and MRVA helps you discover where real code uses them. It's an arms race you win with breadth + community.

Q: Does CodeQL need to build the code? JS/TS, Python, Ruby, and Actions use `build-mode: none` (no build). Compiled languages (Java/Kotlin, C/C++, C#, Go, Swift) need the build observed — autobuild or a manual build — because extraction hooks the compiler.

Q: False negatives — what does CodeQL miss? Unmodeled libraries/sinks (the whole point of the demo), dynamic reflection/ `eval`, flows through serialization it can't follow, and anything outside the analyzed languages. It's a strong net, not a proof of absence.

Q: Precision vs. recall — how do suites decide what's on by default? `default` < `security-extended` < `security-and-quality`. Higher coverage trades in more noise. Queries carry `@precision` and `@problem.severity`; the default suite favors high-precision, high-severity so developers trust the signal. You enable broader suites where a team can absorb the noise.

Q: How does Copilot Autofix relate to CodeQL? CodeQL localizes the vuln and provides the data-flow context; Autofix uses that context to propose a concrete code change with an explanation. CodeQL is the ground truth; the LLM writes the patch suggestion. Human still reviews/merges.

Q: How does CodeQL analyze Actions YAML? There's an `actions` extractor and dedicated query packs (`actions/code-injection`, `actions/untrusted-checkout`, etc.). Same engine, workflows as the "program," expression contexts like `${{ github.event.* }}` as sources and `run:` as the injection sink.

Q: MRVA? Multi-Repository Variant Analysis — run one query across thousands of repos from VS Code to find every instance of a pattern ecosystem-wide. It's "bug class, not bug" at ecosystem scale, and a core Security-Lab workflow.

Talk 2 — Supply chain

Q: How exactly does OIDC trusted publishing remove the token? Instead of a long-lived `NPM_TOKEN` stored in CI, the CI job requests a short-lived **OIDC ID token** from GitHub (`id-token: write`). npm verifies that token against a **trusted publisher** config you set on the package (this repo, this workflow). No secret at rest = nothing to exfiltrate, and the token is minted per-run and expires. Bonus: it enables **signed provenance** automatically.

Q: What's provenance / how does it relate to Sigstore and SLSA? Provenance is a signed attestation of *where and how* a package was built (repo, commit, workflow). npm's provenance uses **Sigstore** for signing/transparency. It moves you up the **SLSA** build-integrity levels. It doesn't stop a malicious maintainer, but it makes tampering and "typosquat built from nowhere" detectable.

Q: If install scripts are off by default, won't builds break? Some packages legitimately need them (native modules via `node-gyp`). You review the blocked list once (`npm install-scripts ls`), approve the few you trust (`approve`), and that decision is recorded in `package.json`. Most packages don't need scripts, so the default is safe and the exceptions are explicit and auditable.

Q: Cooldown vs. pinning vs. lockfiles — why cooldown? They're layers. **Lockfiles** pin exact versions you've already chosen. **Pinning actions to a SHA** stops a mutable tag being swapped. **Cooldown** addresses a different gap: the *moment you adopt a brand-new release*. Most malicious versions are caught within hours–days, so waiting lets ecosystem detection win the race — and **security updates are exempt**, so you don't delay real fixes.

Q: Why is `pull_request_target` dangerous when `pull_request` isn't? `pull_request` runs with a **read-only** token and no secrets for fork PRs. `pull_request_target` runs in the **base** repo's context — secrets + write token — but at the fork's behest. If you then check out and execute fork code, untrusted code runs privileged. The 2026 checkout change refuses that by default unless you add the deliberately-loud `allow-unsafe-pr-checkout`.

Q: What was Shai-Hulud / tj-actions — be accurate. Reference the *pattern*, not invented numbers. **tj-actions** (2025): a popular Action was compromised and modified to dump CI secrets into logs across many repos. **Shai-Hulud**: a self-replicating **npm worm** that used stolen publish tokens to inject itself into more packages — the canonical "compromise → steal → propagate" loop. If you're unsure of a figure, say "on the order of" or defer.

Q: Does OIDC work outside GitHub/CircleCI? Trusted publishing is per-provider (GitHub Actions, CircleCI, …). Elsewhere you fall back to a short-lived, tightly-scoped token plus **staged publishing** (human + 2FA gate) so compromised CI still can't release unilaterally.

Q: Account-protection detail? High-impact npm accounts enter a **72-hour read-only mode** after an email change or 2FA recovery — blunting phishing-based takeover before the attacker can publish.

Q: How does this connect to CodeQL (consistency)? Prevention (these defaults) + detection (CodeQL's `code-injection` / `untrusted-checkout`). Same philosophy as Talk 1: encode the defense once so everyone benefits.

If you get a question you can't answer

Say so, then show reasoning: *"I don't know off-hand. My mental model says X, so I'd expect Y — I'd verify by [reading the extractor docs / testing it in the demo repo]."* That's a **better** signal than bluffing, especially for a research team.

PART B — BEHAVIORAL

Behavioral drafts — Themes 1, 4, 8 (from public background)

How to use this: these are first-draft scripts built from your *public* record (Microsoft Cloud Security Advocate; Must Learn KQL & Must Learn AI Security; myITforum; Windows IT Pro; SANS MS; 30+ yrs speaking/writing). Everything tagged `[VERIFY]` is my inference — correct or cut it. Each runs ~2 minutes. Say "I," land the outcome, end on the Reflection. Swap in real numbers wherever you see `[VERIFY: metric?]` — a concrete figure makes these much stronger.

Sources for the public facts: your Microsoft advocate page, rodtrent.substack.com, the Must Learn KQL GitHub course, and the Definitive Guide to KQL.

Theme 1 — Why security, why GitHub, why the Security Lab

> Structure: a career *thread*, not a résumé. The thread is: **I've spent my career making hard security topics approachable and teaching them at scale.** That IS developer advocacy.

Draft (spoken):

"My whole career has been one thread, even when the technology changed under it: taking something complex and making it approachable for a huge audience. I started by building and running IT communities — myITforum — and editorial teams `[VERIFY: editor-in-chief, Windows IT Pro]`, where the job was translating hard systems problems for practitioners. Then I went deep on security at Microsoft — Sentinel and KQL — and I noticed people were drowning in the *data* side of defense. So I wrote **Must Learn KQL**, an open, free, serialized course on GitHub, and it became one of the default on-ramps for learning KQL `[VERIFY: scale — downloads/translations/book sales?]`. When generative AI arrived, I did it again with **Must Learn AI Security** — 400-plus pages on securing AI `[VERIFY: exact length/outcome]`.

So why security? Because defenders are permanently outnumbered, and the only thing that scales is *teaching* — turning one expert's knowledge into something thousands of people can use. Why open source specifically? Everything I'm proudest of, I gave away on GitHub, because reach and community contribution beat a paywall every time.

And that's exactly why the **Security Lab**, not just GitHub. The Lab's entire premise is that you can't out-hire this problem — you scale expertise through the community: CodeQL queries anyone can write, the query bug-bounty that turns one researcher's insight into protection for everyone, MRVA, the Advisory Database. That's the thing I've been doing for 30 years, pointed at open-source security. A **Developer Advocate** role there isn't a pivot for me — it's the same job I've always loved, with a bigger lever."

Reflection line: "The lesson I keep relearning: the highest-impact security work isn't the bug I personally find — it's the explanation that lets a thousand other people find it."

Theme 4 — A hard technical decision

Problem → Options → Trade-offs → Decision → Outcome → Learning

> Grounded in the **Must Learn KQL** build. If you have a meatier *security-architecture* decision from a large Sentinel engagement, swap it in — but this one is clean, documented, and shows product/technical judgment, which fits a DevRel role well.

Draft (spoken):

"**Problem:** KQL was becoming essential for defenders on Sentinel, but the learning curve was a wall. Microsoft had reference docs, but no approachable on-ramp, and people were bouncing off it. I decided to fix that — and the real decision was *how* to build and deliver it so it would actually scale and last.

Options I weighed: one, write a traditional book or a paid course — polished, but slow, closed, and stale the day it ships. Two, a stream of blog posts — fast and free, but unstructured and un-versioned. Three `[VERIFY: framing]`, treat the curriculum like an open-source *project*: host it on GitHub, serialize it in small, teachable parts, version it, and let the community file issues and PRs — even translations `[VERIFY: were there community translations?]`.

Trade-offs: option three meant no revenue and an ongoing maintenance burden I'd carry personally, and publishing in the open where mistakes are visible. But it maximized reach, let the material stay current, and — the part I cared about — let the community *improve* it.

Decision: I went with the open, versioned, serialized approach, and later added an **assessment** `[VERIFY: Must Learn KQL Assessment, ~2022]` so people could prove they'd learned it.

Outcome: it became one of the go-to ways people learn KQL `[VERIFY: metric — stars, downloads, book, adoption?]`, and later a published book `[VERIFY]`.

Learning: treating *education* like open-source software — versioned, in the open, community-editable — compounds in a way a static artifact never does. I reused that exact playbook for Must Learn AI Security."

Reflection line: "I now default to building teaching artifacts *as* open-source projects, not products — the community turns them into something better than I could alone."

Theme 8 — Ownership in ambiguity

> Their desired arc: **recognized the gap → created clarity → took ownership → brought others along → improved it → applied the learning.** Built from **Must Learn AI Security** (emerging, genuinely ambiguous space). Alternative: **myITforum** is an even purer "I owned a whole community for ~20 years" story — use that if they want longer-horizon ownership.

Draft (spoken):

"**The gap:** when generative AI took off, security teams were being asked to secure something nobody had a playbook for. The space was pure ambiguity — prompt injection, model risks, data leakage — and there was no clear owner of 'how does a normal defender actually get started here.' `[VERIFY: your framing of the moment, ~2023]`

Creating clarity: rather than wait for someone to define it, I started writing **Must Learn AI Security** in the open — breaking a chaotic topic into small, concrete, teachable pieces, one at a time, published where anyone could read and respond. `[VERIFY: cadence]`

Taking ownership / bringing others along: I committed to it publicly and kept shipping, which pulled in feedback, corrections, and real-world questions from practitioners `[VERIFY: community response`

`specifics]`. The series grew past **400 pages** and became a formal, organized resource `[VERIFY: book/compendium]` — and it fed directly into my work explaining tools like Microsoft Security Copilot `[VERIFY]`.

Improvement + what I carried forward: I turned an ambiguous, intimidating space into an on-ramp a lot of defenders actually used `[VERIFY: metric?]`. What I carried forward: in a space this ambiguous, *publishing early and iterating in the open* creates clarity faster than trying to design the perfect taxonomy first. Shipping the v1 is what recruits the collaborators."

Reflection line: "Ambiguity doesn't get resolved by waiting for ownership to be assigned — you create clarity by putting a rough, honest v1 in the open and letting people build on it."

Notes on using these

- **Fill the `[VERIFY]` and `[VERIFY: metric?]` tags** — a real number (downloads, pages, adoption, engagement) turns a good answer into a memorable one.
- **Don't memorize word-for-word.** Learn the beats; speak it fresh so it sounds like you.
- **Tie back to the Lab** in Theme 1 and (lightly) Theme 4 — the "scale expertise through community / open source" thread is your single strongest fit, and it mirrors both your talks.
- Want me to also draft **Theme 2 (OSS/curiosity)** and **Theme 9 (definition of excellent work)**? Those are easy wins from the same material.

Behavioral drafts — Themes 2 & 9 (from public background)

Same rules as the T1/T4/T8 file: built from your public record, `[VERIFY]` = my inference to confirm or cut, `[VERIFY: metric?]` = drop in a real number. ~2 minutes each. Say "I," end on the Reflection. Keep the stories *distinct* from Themes 1/4/8 (don't retell Must Learn KQL as a decision here — use the angles below).

Theme 2 — Security, open source & technical curiosity

> This one isn't a single STAR story — they want to see *genuine* engagement: security work, OSS involvement, how you stay current, and **what you're exploring now + what you're doing with it.** Lead with curiosity as a habit, then give concrete proof.

Draft (spoken):

"Curiosity is kind of my operating system — I learn something by teaching it in public, and I do it out loud on GitHub and my blog so other people can build on it.

On the **security** side, most of my hands-on work has been in detection and threat hunting — KQL, Sentinel, helping teams actually interrogate their security data `[VERIFY: largest Sentinel implementations]`. On the **open-source** side, the things I'm proudest of are public repos, not internal docs — Must Learn KQL, Must Learn AI Security — because an open repo invites issues, PRs, and translations `[VERIFY]`, and it keeps improving after I stop touching it.

How I **stay engaged** with the community: I publish constantly `[VERIFY: Substack cadence]`, I speak at conferences `[VERIFY: 30+ years / which ones]`, and I show up on podcasts `[VERIFY: Practical 365, Microsoft Threat Intelligence]`. I treat that two ways — as teaching, and as a listening post for what practitioners are actually stuck on.

What I'm **exploring right now** is the collision of **AI and security** — both securing AI systems (prompt injection, model risk — the Must Learn AI Security work) and using AI to make defenders faster, like Security Copilot `[VERIFY]`. And more recently I've gone deep on **CodeQL and static analysis** — 'code as data,' models-as-data, how you describe a whole bug class once and catch every instance `[VERIFY: your framing]`. What I'm *doing* with it is exactly what the Security Lab does: turning what I learn into something other people can pick up and run with — which is why the Lab's AI-plus-static-analysis direction, like the Taskflow Agent, genuinely excites me."

Reflection line: "I've learned I don't really understand something until I've taught it in the open and had the community poke holes in it — so 'learning' and 'advocacy' are the same activity for me."

Theme 9 — My definition of excellent work

> Have a *philosophy* **and** a real example where you hit the bar and knew it. Pick a different lens than Theme 4: there, Must Learn KQL was a *decision*; here, make it about a *quality bar* and how you *measured* it.

Draft (spoken):

"**My definition:** good work is correct; excellent work is correct *and* understood and reusable by the next person — it solves the real underlying problem, it's maintainable, and you can actually *measure* that it landed. In my world, the last part matters most: it's easy to produce content that looks great and teaches nothing. Excellent means the audience can go *do* the thing afterward.

An example: with Must Learn KQL I could see people reading it, but 'read' isn't 'learned.' So I held myself to a higher bar — I built an actual **assessment** `[VERIFY: Must Learn KQL Assessment, ~2022]` so learners could *prove* they could write KQL, and so I'd get a real signal about where the material was failing. That did two things: it turned a pile of articles into something with a measurable outcome, and the results told me exactly which sections to rewrite `[VERIFY: what the data showed / pass rates?]`. I iterated on the weak spots instead of guessing.

Why that's my bar: understanding the real problem (people needed to *apply* KQL, not admire it), maintainability (open and versioned so it survives me), communication (small, teachable pieces), and a measurable outcome (the assessment). When all four line up, I know it's excellent — not because it's polished, but because it *changed what someone could do* `[VERIFY: adoption/impact metric?]`."

Reflection line: "I stopped trusting 'this looks great' as a quality signal years ago — now I ask 'how will I know it actually worked?' before I ship, and build that measure in from the start."

Notes

- **Theme 2** lets you name **CodeQL / Taskflow Agent** as live curiosity — a strong, authentic "why the Lab" reinforcement. Keep it honest: frame it as recent, genuine exploration.
- **Theme 9's** measurable-outcome angle (the assessment) is distinct from Theme 4's decision angle, so you won't sound repetitive if both come up.
- Fill the `[VERIFY: metric?]` tags — "excellent work" answers are far stronger with a number.
- Remaining themes with no draft yet: **3** (collaboration/different perspectives), **5** (helping others — two-way), **6** (learning & growth), **7** (remote/async), **10** (a failure). Those need a real anecdote from you; the workbook has prompts. Want me to draft any once you give notes?

Behavioral draft — Theme 6: Learning & growth (from public background)

Same rules: `[VERIFY]` = my inference to confirm/cut, `[VERIFY: metric?]` = drop in a real number. ~2 minutes. They stress: **what are you *actively* learning, and what are you *doing* with it?** Concrete beats general. Keep this distinct from Theme 2 — there you talked about curiosity as a habit and community engagement; **here, focus on your learning *method* and *trajectory*, and the learning→output loop.**

Draft (spoken):

"The way I grow is deliberate: I pick a hard area, commit *publicly* to teaching it, and let that deadline force me to actually master it. Publishing is my study method — if I can't explain it simply in the open, I don't really know it yet.

You can see that as a trajectory. I went deep on **systems management**, then committed to **security data and threat hunting** — KQL and Sentinel — and taught my way to fluency with Must Learn KQL. I even went back for formal depth: a **master's in Information Security Engineering from SANS** `[VERIFY: MS, SANS Technology Institute]`, because I didn't want to be only self-taught in security. Then generative AI arrived and I retooled again into **AI security** — prompt injection, model risk, securing AI systems — and turned that into Must Learn AI Security `[VERIFY: 400+ pages]`.

What I'm actively learning right now is two things. One, **AI *for* security** — how tools like Security Copilot change a defender's workflow `[VERIFY]`. Two — and this is recent and directly relevant — **CodeQL and static analysis**: 'code as data,' writing queries, models-as-data, the idea that you describe a bug class once and find every instance `[VERIFY: your framing]`.

And here's what I'm *doing* with it — which is the part I care about most. I don't learn CodeQL to have learned it; I built a small vulnerable app, wrote the queries and a model, and turned the whole thing into a teachable demo and write-up `[VERIFY: your interview project — keep or soften as appropriate]`. That's my loop every time: learn it, build something real with it, then package it so someone else gets there faster. It's exactly the Security Lab's model — expertise only matters once you've made it reusable."

Reflection line: "The biggest growth lesson of my career: the fastest way to *learn* something is to commit to *teaching* it before you're ready — the obligation pulls the mastery forward."

Notes

- The CodeQL line is genuinely true for you right now (you built exactly that for this loop) — it's a strong, authentic "I practice what I'm interviewing for" signal. Soften the project reference if you'd rather not foreground that it was interview prep; "I built a small vulnerable app and modeled it in CodeQL" stands on its own.
- Distinct from Theme 2: Theme 2 = curiosity *habit* + community; Theme 6 = learning *method* + *trajectory* + the learn→build→teach loop. If both come up, lead each with its own angle.
- Fill the `[VERIFY]` tags — especially the SANS degree and the AI Security page count.

- Still undrafted (need your anecdote): **3** collaboration/disagreement, **5** mentoring (two-way), **7** remote/async, **10** a failure. Paste a few bullets for any and I'll match the format.

Behavioral & culture workbook

The behavioral interview is **half the loop** and they grade it hard. You can't script it, but you *should* walk in with ~6–8 real stories you can flex across themes. This workbook gives you the structure; **you supply the stories.** Paste rough notes back to me and I'll help shape any of them into tight STAR+R form.

> Format for every answer: **STAR + Reflection**. Spend most of your airtime on **Action → Result → Reflection**, not background. Use **"I"**, not "we" — they want *your* contribution. ~2 minutes per answer.
>
> S — Situation (1–2 sentences of context) T — Task (what *you* were responsible for) A — Action (what *you specifically* did, and *why* — reasoning matters) R — Result (what changed; quantify if you can) **R — Reflection (what you learned and now do differently)**

Build a story bank first (do this before drilling questions)

List 6–8 real experiences. Strong stories are specific, recent-ish, and show *your* decisions. One story can cover several themes — map them so you're never caught without one.

#	Story (1 line)	Themes it can cover	Metric / outcome
1			
2			
3			
4			
5			
6			

Aim to cover: a hard technical decision · a collaboration/disagreement · a time you mentored · a time you owned ambiguity · a failure/learning · an advocacy/teaching win · an OSS or community contribution.

Theme 1 — Motivation: why security, why GitHub, why the Security Lab

They explicitly warn against "GitHub is a great company." Be specific and personal. Prompts: - What's the *origin moment* that pulled you toward security? - Why **open-source** security specifically — what do you believe about it? - Why the **Security Lab** over other security teams? (Use the research brief: the "scale expertise through community" mission, MRVA, query bounties, Taskflow Agent.) - This is a **Developer Advocate** role — connect your love of *teaching/communicating* security to their mission of enabling the community. Your two talks are living proof.

Draft: - Why security: _ - Why open source: _ - Why the Security Lab (name a specific program + why it resonates): _ - Why me / why this role (the DevRel + security combination): _

Theme 2 — Security, open source & technical curiosity

Prompts: a security project you're proud of · an OSS contribution · how you stay current (blogs, communities, conferences) · what you're exploring right now. - Story: _ - What I'm currently exploring & *what I'm doing*

with it: _

Theme 3 — Collaboration & different perspectives

Prompt: a time someone approached a problem differently, you sought the challenge, and your approach *changed*. Emphasize what changed and what you learned — not that you were right. - S/T: _ · A (what *you* did to invite the other view): _ - R + Reflection: _

Theme 4 — Technical problem solving

Use their exact frame: **Problem → Options → Trade-offs → Decision → Outcome → Learning.** They care about *reasoning* as much as the result. Have at least one meaty one. - Problem: _ - Options considered: _ - Trade-offs weighed: _ - Decision + why: _ - Outcome: _ - Learning: _

Theme 5 — Helping & developing others

Prompt: someone you mentored/coached. Strong version = it was **two-way** (you learned too). - Who / situation: _ - What you did: _ - Their outcome + **what you learned from them**: _

Theme 6 — Learning & growth

Prompt: what you're *actively* learning and **what you're doing with it** (concrete > general). - Currently learning: _ - Applied how: _

Theme 7 — Remote & asynchronous collaboration

GitHub is heavily distributed. Prompt: show how you communicate in writing, document, keep people informed, and **decide when sync is actually needed**. - Example of great async work (a doc, an RFC, a well-run issue/PR thread): _ - A time you chose sync *on purpose* and why: _

Theme 8 — Ownership & ambiguity

Their desired arc: **recognized the gap → created clarity → took ownership → brought others along → improved it → applied the learning after.** Avoid blaming others for the ambiguity. - The gap I noticed: _ - How I created clarity: _ - What I owned / how I brought others along: _ - Improvement + what I carried forward: _

Theme 9 — Your definition of excellent work

Have a *philosophy* **and** a real example. Good vs. excellent often = understanding the underlying problem, maintainability, impact, communication, measurable outcomes. - My definition (2–3 sentences): _ - An example where I hit that bar (and how I knew): _

Theme 10 — A failure / something you'd do differently

(Not explicitly listed but almost always asked.) Pick a real one; lead with the learning. - What happened, what I owned, what changed since: _

Dry-run drill

- [ ] Each theme has at least one mapped story.

- [ ] Each story runs ~2 min and is mostly Action/Result/Reflection.
- [ ] Every story has a one-line **Reflection**.
- [ ] You say **"I"** and name a concrete outcome.
- [ ] You've said **"why the Security Lab"** out loud without clichés.
- [ ] Record yourself once; cut the background in half.

Next step: paste me rough notes for Themes 1, 4, and 8 (the highest-signal ones) and I'll turn them into tight STAR+R drafts you can rehearse.

PART C — RESEARCH & QUESTIONS

GitHub Security Lab — research brief

Grounding for "why the Security Lab," your behavioral answers, and your questions. **Re-verify the live numbers on securitylab.github.com the morning of** — stats move. Dates below are as of this prep.

> Reminder: the role is **Developer Advocate** on the Security Lab. The whole loop is effectively a DevRel audition — they're watching *how you teach and tell the story* as much as what you know. Frame your motivation around **enabling the community**, not just doing research yourself.

Mission (say it in your words, don't quote the website)

GitHub Security Lab exists to **secure the world's open-source code by mobilizing the global security community** — not by trying to review everything themselves. The founding framing (2019) named three structural problems, and they're still the best way to explain *why* the Lab exists: - **Scale** — the JavaScript ecosystem alone has 1M+ packages; nobody can hand-audit that. - **Expertise shortage** — developers outnumber security pros by roughly 500:1. - **Coordination** — the world's security experts are scattered across thousands of orgs.

The Lab's answer: **encode security expertise so it scales** (CodeQL queries, models, advisories) and **build a community** that contributes it. That's the thread connecting every program below — and it's exactly the thread in both your talks.

What they actually do (programs to name)

- **CodeQL** — the "code as data" engine. The Lab writes and curates queries, and — key for a DevRel role — helps *the community* write them. (Your Talk 1.)
- **Bug bounty for queries, not just bugs** — a distinctive idea worth calling out: they pay researchers for **CodeQL queries that find a whole *class* of vulnerability**, so one submission protects everyone via code scanning. "Eradicate at scale," not one-off bugs.
- **GitHub Advisory Database / GHSA** — tens of thousands of curated advisories; the backbone of Dependabot alerts. (One of your two original topic options.)
- **Multi-Repository Variant Analysis (MRVA)** — run a CodeQL query across *thousands* of repos at once to find every instance of a pattern ecosystem-wide. The literal embodiment of "find the bug class, not just the bug."
- **CodeQL community packs** & the **CodeQL "Wall of Fame"** — community-contributed queries and recognition for researchers who find CVEs with variant analysis.
- **Security Lab Taskflow Agent** — newer, AI-assisted vulnerability triage (LLM taskflows over CodeQL alerts). Shows where they're heading: AI + static analysis. (A topic option.)
- **The Secure Code Game** — an in-repo, gamified secure-coding learning experience. Pure DevRel/education. (A topic option.)
- **Education & community** — AppSec training, office hours for maintainers, and research published on the blog + Bluesky/Mastodon/LinkedIn.
- **Supply-chain hardening** — the npm + Actions work in your Talk 2 is the Lab/GitHub security org's current frontier.

Headline stats (verify live; use ranges, don't overclaim)

- **~1,200+ vulnerabilities** found by the Lab, with **~900+ CVEs** credited to their work.
- **35,500+** curated security advisories in the GitHub Advisory Database.
- Bug-bounty rewards historically up to the **~$5–6K** range for high-value query work.
- Began at **GitHub Universe 2019**; launched with partners incl. Microsoft, Google, Mozilla, Oracle, Uber, VMware, Trail of Bits, NCC Group, F5, J.P. Morgan. (Sources: securitylab.github.com; github.blog; the 2019 launch post.)

Proof points you can drop into an answer

- CodeQL variant analysis found **RCE in high-profile Java apps (2020)**, which chained into fixing a critical vuln in **Germany's COVID-19 response infrastructure** — a clean "one query → broad real-world impact" story.
- Variant analysis has been pointed at the **Linux kernel and Chromium**.
- The **2026 supply-chain changes** (npm 12 install scripts off, OIDC trusted publishing, safer checkout defaults, Dependabot cooldown) — your Talk 2 — are current and topical.

How "research turns into impact" (their favorite phrase — be ready to riff)

Lab's flywheel: **research a bug → generalize it into a CodeQL query/model → ship it into code scanning + MRVA → the whole ecosystem is now protected → credit/teach the community so they do it too.** Both your talks are instances of this flywheel — say that explicitly.

Why this matters for YOUR two talks (consistency hook they grade)

- Talk 1 (CodeQL) = **detection**, and the "models as data" lever = *encode expertise so it scales* = the Lab's mission in one line.
- Talk 2 (supply chain) = **prevention**, secure-by-default = *protect people who do nothing*.
- Together: **detect + prevent**, and **CodeQL scans both your code and your CI** — one engine, two surfaces. That's your through-line; name it in both talks' openings or closings.

Questions to ask them

Goal: **start a conversation**, not fetch a fact you could Google. Pick 4–6 you genuinely care about; have a couple extra in reserve. Jot a one-line note after each answer — referencing it later ("you mentioned earlier…") is a strong signal. Tailor each to the interviewer's role (researcher vs. manager vs. DevRel).

About the mission & where it's going

1. The Lab's premise is that you can't out-hire the problem — you scale expertise through the community. **Where does that model work best today, and where does it still break down?**
2. With the **Taskflow Agent** and AI-assisted triage, how is the Lab thinking about the line between what the LLM decides and what a human researcher must still own?
3. If you look 12–18 months out, **where does the Lab most want to have more impact** that it can't quite reach yet?

About research → impact (their phrase)

4. When a researcher finds a novel bug class, what does the path from **"interesting finding" to "query shipping in code scanning / MRVA"** actually look like — and where does it get stuck?
5. How do you measure whether a piece of research actually moved the needle for the ecosystem, versus just generating a CVE?

About the Developer Advocate role specifically

6. For this DevRel role, **what does a great first 90 days look like** — more writing/queries, more community/conference presence, or more maintainer enablement?
7. How does the Lab decide **which audiences to invest in** — individual maintainers, security researchers, or enterprise security teams? They need pretty different stories.
8. What's a piece of security tech the team believes is genuinely important but that developers still **don't "get"** — where better advocacy would change adoption?

About the craft & technical decisions

9. CodeQL constantly trades **precision vs. coverage**. How does the team decide when a query is "good enough" to enable by default versus leave opt-in?
10. On the supply-chain work — install scripts off by default, OIDC trusted publishing — **how do you weigh ecosystem friction against security** when changing a default that affects millions of builds?

About the team & how it works

11. GitHub is famously remote/async. **How does the Lab do deep security research asynchronously** — what's written down vs. what still needs a synchronous room?
12. When the team disagrees on a technical call, how does that usually get resolved?

Closing-style question (good last one)

13. **What separates someone who's good in this role from someone who's exceptional?**

Avoid: "What does the Security Lab do?", "Is CodeQL free?", benefits/logistics (save for recruiter), anything answered on the first page of their site.